



UNIVERSITÀ DEGLI STUDI DI SALERNO

# Penetration Testing Report

Academy – Cybersecurity

Kioptrix Level 1

## Gruppo 15

0612709539 – Francesco Cangianiello  
0612709671 – Andrea Ciliberti  
0612709638 – Serena Fierro

## Sommario

Il presente documento costituisce il report dell'attività di **Penetration Testing** condotta sulla macchina identificata come "Kioptrix Level 1".

L'obiettivo è stato valutare la sicurezza del sistema attraverso la simulazione di un attacco informatico mirato, eseguito secondo una metodologia **BlackBox** (senza alcuna conoscenza pregressa o credenziale fornita).

L'analisi ha evidenziato un sistema profondamente vulnerabile a causa di una spessa obsolescenza software. Sono state identificate complessivamente **130 evidenze di insicurezze**, tra cui spiccano **3 vulnerabilità di livello critico (CVSS 10.0)** a carico dei servizi di rete e del sistema operativo. Lo sfruttamento di tali falle ha permesso di bypassare ogni meccanismo di difesa e di ottenere l'accesso remoto con i massimi privilegi di amministrazione (**root**), portando alla compromissione totale del sistema.

Lo scopo di questo report è di illustra l'impatto sulla sicurezza, fornire una panoramica chiara dei vettori di attacco testati e mostrare un piano di **Remediation** per mitigare i rischi e mettere in sicurezza l'asset.

# Indice

|          |                                                                                                          |           |
|----------|----------------------------------------------------------------------------------------------------------|-----------|
| <b>1</b> | <b>EXECUTIVE SUMMARY</b>                                                                                 | <b>4</b>  |
| 1.1      | Obiettivo dell'Incarico . . . . .                                                                        | 4         |
| 1.2      | Risultati ottenuti . . . . .                                                                             | 4         |
| 1.3      | Valutazione Globale del Rischio . . . . .                                                                | 5         |
| 1.4      | Raccomandazioni Strategiche (Contromisure) . . . . .                                                     | 6         |
| <b>2</b> | <b>ENGAGEMENT HIGHLIGHTS</b>                                                                             | <b>7</b>  |
| 2.1      | Definizione accordi preliminari tra le parti coinvolte . . . . .                                         | 7         |
| 2.2      | Requisiti legali e operativi stabiliti prima dell'avvio del test . . . . .                               | 7         |
| 2.3      | Modalità di esecuzione del penetration testing . . . . .                                                 | 7         |
| 2.4      | Metodologia adottata . . . . .                                                                           | 8         |
| 2.5      | Obiettivi del test . . . . .                                                                             | 8         |
| 2.6      | Ruoli e Responsabilità . . . . .                                                                         | 8         |
| <b>3</b> | <b>VULNERABILITY REPORT</b>                                                                              | <b>9</b>  |
| 3.1      | Contenuti principali . . . . .                                                                           | 9         |
| 3.1.1    | Vulnerabilità RCE su servizio Samba (trans2open) . . . . .                                               | 10        |
| 3.1.2    | Vulnerabilità Critica su modulo Apache mod_ssl 2.8 (RCE) . . . . .                                       | 11        |
| 3.1.3    | Privilege Escalation locale tramite Vulnerabilità del Kernel<br>(ptrace-kmod) . . . . .                  | 12        |
| 3.2      | Scenari di Compromissione . . . . .                                                                      | 12        |
| 3.3      | Impatto sulla sicurezza (Effetti e rischi per l'asset) . . . . .                                         | 13        |
| 3.4      | Valutazione esposizione (Possibili conseguenze operative e di sicurezza) . . . . .                       | 13        |
| <b>4</b> | <b>REMEDIATION REPORT</b>                                                                                | <b>14</b> |
| 4.1      | Piano di mitigazione . . . . .                                                                           | 14        |
| 4.2      | Raccomandazioni di sicurezza . . . . .                                                                   | 14        |
| 4.2.1    | Interventi sul servizio Samba . . . . .                                                                  | 14        |
| 4.2.2    | Interventi sul Kernel Linux . . . . .                                                                    | 15        |
| 4.3      | Irrobustimento generale del sistema . . . . .                                                            | 15        |
| 4.4      | Obiettivi di Sicurezza . . . . .                                                                         | 15        |
| <b>5</b> | <b>FINDINGS SUMMARY</b>                                                                                  | <b>16</b> |
| 5.1      | Dettaglio delle Scansioni e Superficie di Attacco . . . . .                                              | 17        |
| 5.2      | Grafico delle vulnerabilità rilevate . . . . .                                                           | 17        |
| <b>6</b> | <b>DETAILED SUMMARY</b>                                                                                  | <b>18</b> |
| 6.1      | Catalogo Dettagliato delle Vulnerabilità . . . . .                                                       | 18        |
| 6.2      | Vulnerabilità Critiche . . . . .                                                                         | 18        |
| 6.2.1    | ● RCE su servizio Samba trans2open – CVE-2003-0201 (Anali-<br>si Manuale, OpenVAS, Nessus) . . . . .     | 18        |
| 6.2.2    | ● RCE su Apache mod_ssl (OpenSSL-too-open) – CVE-2002-<br>0082 (Nessus, OpenVAS) . . . . .               | 19        |
| 6.2.3    | ● Privilege Escalation tramite Kernel Linux (ptrace-kmod) –<br>CVE-2003-0127 (Analisi Manuale) . . . . . | 19        |
| 6.3      | Vulnerabilità Alte . . . . .                                                                             | 20        |

---

|          |                                                                                                  |           |
|----------|--------------------------------------------------------------------------------------------------|-----------|
| 6.3.1    | ● Deprecated SSH-1 Protocol Detection – CVE-2001-0361, CVE-2001-0572 (Nessus, OpenVAS) . . . . . | 20        |
| 6.3.2    | ● Apache Chunked Encoding Remote Overflow – CVE-2002-0392 (Nessus) . . . . .                     | 20        |
| 6.4      | Vulnerabilità Medie . . . . .                                                                    | 20        |
| 6.4.1    | ● Enumerazione Utenti tramite servizio Samba (Analisi Manuale) . . . . .                         | 20        |
| 6.4.2    | ● HTTP TRACE / TRACK Methods Allowed – CVE-2003-1567 (Nessus) . . . . .                          | 21        |
| 6.4.3    | ● Webalizer Cross Site Scripting – CVE-2001-0835 (Nessus, OpenVAS) . . . . .                     | 21        |
| 6.5      | Vulnerabilità Basse . . . . .                                                                    | 21        |
| 6.5.1    | ● ICMP Timestamp Reply Information Disclosure – CVE-1999-0524 (Nessus, OpenVAS) . . . . .        | 21        |
| <b>7</b> | <b>Considerazioni finali</b>                                                                     | <b>22</b> |
| <b>8</b> | <b>Riferimenti bibliografici</b>                                                                 | <b>23</b> |

# 1 EXECUTIVE SUMMARY

## 1.1 Obiettivo dell'Incarico

Nel periodo compreso tra il 26/05 e il 16/06, il nostro team ha condotto un **Penetration Test** mirato sull'infrastruttura identificata come "Kioptrix Level 1".

L'attività è stata progettata per simulare un attacco **informatico realistico**, con lo scopo di identificare le vulnerabilità presenti nel sistema e verificarne l'impatto attraverso tecniche di sfruttamento (**exploitation**).

Nello specifico, i test si sono concentrati sulla valutazione del rischio reale, verificando se un attaccante esterno potesse arrivare a ottenere un accesso remoto non autorizzato con i massimi privilegi di amministrazione (**root**).

L'obiettivo finale di questa simulazione è stato quello di testare la resilienza della macchina ed **evidenziare le criticità di sicurezza**, fornendo indicazioni chiare per la loro mitigazione prima che queste potessero essere sfruttate attivamente da attori malevoli.

## 1.2 Risultati ottenuti

Durante l'analisi automatizzata e manuale dell'infrastruttura sono state rilevate complessivamente **130 vulnerabilità**.

Tra queste, spiccano **5 vulnerabilità di livello Critico** e **18 di livello Alto**, che espongono l'asset analizzato a un rischio grave.

Nel dettaglio:

- **Compromissione del Perimetro Esterno (Servizio Web):** I servizi esposti al pubblico utilizzano componenti crittografici obsoleti e non più sicuri. Sfruttando questa debolezza, un attaccante esterno può eludere completamente le misure di sicurezza e ottenere un accesso remoto non autorizzato alla macchina.  
Questo scenario apre la strada ad **attacchi più profondi**, pur in totale assenza di credenziali valide.
- **Difetto Strutturale e Dominio Totale (Sistema Operativo):** La base del sistema operativo (**Kernel Linux**) ha ampiamente superato il suo ciclo di vita e presenta difetti strutturali impossibili da correggere con semplici aggiornamenti. Sfruttando un accesso iniziale anche limitato (come quello ottenuto violando il servizio web), un attaccante può aggirare le restrizioni di sicurezza e scalare i propri privilegi fino a diventare amministratore della macchina, esponendo la macchina a gravi problemi.

- **Esposizione dei Dati e Controllo Immediato (Condivisione File):** Il sistema che si occupa della condivisione delle risorse di rete (Samba) presenta **gravi misconfiguration e componenti non aggiornati**. Questa esposizione genera un duplice rischio:
  - \* da un lato, permette a chiunque di interrogare il sistema e raccogliere informazioni aziendali sensibili in forma completamente anonima.
  - \* dall'altro, espone il server ad attacchi diretti e automatizzabili che garantiscono all'attaccante l'acquisizione immediata dei massimi privilegi amministrativi, avendo il pieno controllo della macchina.

### 1.3 Valutazione Globale del Rischio

Il **livello di rischio complessivo** per il sistema analizzato è valutato come **CRITICO**.

L'infrastruttura presenta gravi carenze di sicurezza derivanti dall'utilizzo di servizi di rete (come server web e protocolli di condivisione file) e componenti di base obsoleti e non più supportati.

Tali criticità permettono a un potenziale attaccante esterno, anche senza disporre di alcuna credenziale di accesso, di sfruttare vulnerabilità pubbliche note per eseguire codice arbitrario e ottenere il controllo totale della macchina con i massimi privilegi (root). Questo scenario compromette integralmente la riservatezza, l'integrità e la disponibilità del sistema.

## 1.4 Raccomandazioni Strategiche (Contromisure)

Per riportare il livello di rischio entro soglie accettabili e proteggere l'infrastruttura da compromissioni simili, si raccomanda alla Direzione di dare priorità alle seguenti iniziative:

- **Revisione dei Controlli di Accesso:** Richiedere al team di sviluppo un intervento immediato per validare correttamente i permessi degli utenti su ogni richiesta applicativa.
- **Gestione degli Aggiornamenti:** Richiede una fase importante di identificazione e installazione tempestiva degli aggiornamenti di sicurezza sui servizi esposti e sul sistema operativo usato.
  - \* Qualora non sia possibile aggiornare componenti datati per ragioni tecniche o di compatibilità, è importante isolare la macchina a livello di rete (come mediante regole firewall rigide) per limitare i danni in caso di compromissione, oppure procedere con la temporanea dismissione del servizio in questione.
- **Minimizzazione della Superficie di Attacco:** Disabilitare tutte le porte e i servizi di rete non strettamente necessari all'operatività aziendale. Un'attenta configurazione riduce drasticamente i punti di ingresso a disposizione di un potenziale attaccante.

## 2 ENGAGEMENT HIGHLIGHTS

### 2.1 Definizione accordi preliminari tra le parti coinvolte

L'attività è stata concordata tra il **cliente** e il **team di Security Assessment** (Gruppo 15).

L'accordo prevede la simulazione di un **attacco informatico** controllato al fine di mappare lo stato di sicurezza dell'asset, identificare le criticità e fornire le relative misure di mitigazione (Remediation).

**Periodo di esecuzione:** Da Maggio 2026 a Giugno 2026.

**Target:** Macchina virtuale "Kioptrix Level 1".

### 2.2 Requisiti legali e operativi stabiliti prima dell'avvio del test

Prima dell'avvio delle scansioni, sono stati definiti e rispettati i seguenti **vincoli operativi**:

- **Autorizzazione Formale:** Il team è stato esplicitamente autorizzato a condurre attività di port scanning, vulnerability assessment , tentativi di intrusione (exploitation) e Maintaining Access sul target concordato.
- **Isolamento dell'Ambiente:** Al fine di rispettare i requisiti legali e prevenire qualsiasi interferenza con reti esterne o sistemi di terze parti, i test sono stati eseguiti esclusivamente all'interno di un ambiente di laboratorio chiuso e rigorosamente segmentato (Rete NAT).

### 2.3 Modalità di esecuzione del penetration testing

L'attività di attacco e analisi è stata eseguita secondo le seguenti specifiche tecniche:

- **Approccio: BlackBox (Scansione non Autenticata).** Il team ha operato senza alcuna conoscenza pregressa dell'infrastruttura, dei servizi in esecuzione o delle credenziali di accesso.
- **Ambito di scansione (Port Scan):** È stato configurato il controllo completo su tutte le porte TCP nel range 1-65535.
- **Profondità dei test web:** È stata eseguita sia la scansione automatica dei servizi sia il crawling mirato delle directory applicative con l'obiettivo di ottenere file o configurazioni nascoste.



## 2.4 Metodologia adottata

E' stato adottato un approccio strutturato combinando test automatici e verifiche manuali attraverso i seguenti strumenti:

- **Vulnerability Scanning di Rete:** Utilizzo di **OpenVAS** (configurazione: Full and Fast) e **Nessus** (configurazione: Basic Network Scan & Web Application tests).
- **Vulnerability Scanning Web:** Impiego di **Nikto** per l'analisi delle vulnerabilità del server Apache e del modulo mod\_ssl.
- **Directory Crawling:** Utilizzo di **Dirb** e **Gobuster** per l'esplorazione delle cartelle del server web (scoprendo l'assenza di pagine pubblicate e l'istanza isolata di Webalizer).

## 2.5 Obiettivi del test

L'ingaggio si è posto i seguenti obiettivi chiave:

- **Identificare e catalogare tutte le vulnerabilità** presenti sull'asset (il sistema ne ha totalizzate complessivamente 130).
- **Valutare la presenza di falle critiche** con punteggio CVSS 10.0 (individuate poi nei servizi Samba, OpenSSL e nel kernel Linux).
- **Verificare l'efficacia dei vettori di attacco applicativi** ed escludere la presenza di vulnerabilità web standard sfruttabili (come SQL Injection o XSS).

## 2.6 Ruoli e Responsabilità

Per garantire il corretto svolgimento delle attività, sono state definite le seguenti responsabilità:

- **Team di Analisi (Gruppo 15):** Incaricato dell'attacco informatico alla macchina target e della stesura della documentazione dei vari report.
- **Referenti Infrastruttura (Cliente):** Responsabili della fornitura dell'ambiente di test (macchina target Kioptrix) e destinatario finale di tutta la documentazione prodotta.

## 3 VULNERABILITY REPORT

### 3.1 Contenuti principali

L'analisi di sicurezza condotta sulla macchina ha evidenziato un sistema caratterizzato da un numero elevato di vulnerabilità. I dati salienti emersi includono:

- **Volume complessivo delle vulnerabilità:** Sono state rilevate **130 vulnerabilità uniche totali**, identificate attraverso l'azione combinata degli scanner **OpenVAS (78 evidenze)** e **Nessus (116 evidenze)**. Si precisa tuttavia che una parte consistente di queste è **classificata come puramente informativa** e non rappresenta un rischio diretto per l'asset in questione.
- **Presenza di falle critiche:** Sono state individuate tre specifiche vulnerabilità di massima gravità, ciascuna associata al punteggio estremo di CVSS Score 10.0 nello specifico:
  - \* **OpenSSL openssl-too-open**
  - \* **Servizio Samba**
  - \* **Linux Kernel ptrace-kmod**
- **Esito dell'analisi web applicativa:** I test condotti con **Nikto, Nessus Web Scan, Dirb e Gobuster** hanno confermato che il server Apache non espone alcun applicativo reale e non ospita file nascosti (siano essi lasciati intenzionalmente dal creatore della macchina o derivati da errate configurazioni).  
Di conseguenza, minacce tipiche a livello applicativo come **SQL Injection, Cross-Site Scripting (XSS) o File Upload** non trovano modalità d'attacco disponibili, portando il team a scartare a monte questa specifica tipologia di offensiva.

I tre vettori critici con punteggio CVSS 10.0 identificati sul sistema bersaglio sono descritti di seguito in dettaglio:

### 3.1.1 Vulnerabilità RCE su servizio Samba (trans2open)

**Livello di Rischio:**

**CRITICO** (CVSS: 10.0)

#### Descrizione:

Il sistema esegue la versione obsoleta Samba 2.2.1a, la quale risulta esposta ad accessi non autenticati (**Null Session**) tramite *rpcclient*. Questa problematica, derivante da errate configurazioni di base, espone il servizio a interrogazioni esterne non autorizzate.

#### Dettaglio Tecnico e Sfruttamento:

La vulnerabilità nota come "**trans2open**" (CVE-2003-0201) è causata da un errore di gestione della memoria (**Buffer Overflow**) all'interno del demone *smbd* di Samba. Il difetto si manifesta durante l'elaborazione di messaggi SMB di tipo "**Transaction2 Open**" malformati. Poiché il servizio permette connessioni anonime, un attaccante remoto può inviare una sequenza di pacchetti appositamente creati per sovrascrivere lo stack di memoria del processo. Durante la fase di exploitation, avvalendosi del framework **Metasploit**, è stato iniettato in memoria un payload malevolo che ha forzato l'applicazione a eseguire codice arbitrario. Questa operazione ha permesso di instaurare con successo una connessione di ritorno (**Reverse Shell**) verso la macchina dell'attaccante.

#### Impatto:

La gravità di questa vulnerabilità è massima. Sfruttando questa debolezza, un attaccante remoto e non autenticato ottiene istantaneamente un terminale di esecuzione con i massimi privilegi di sistema (utente **root**). L'attaccante assume il pieno controllo del server, ottenendo la capacità di:

- Accedere, modificare o esfiltrare qualsiasi **dato sensibile** presente sulla macchina.
- Installare impianti malevoli (**backdoor** o **rootkit**) per garantirsi un accesso persistente e non rilevabile.

### 3.1.2 Vulnerabilità Critica su modulo Apache mod\_ssl 2.8 (RCE)

**Livello di Rischio:**

**CRITICO** (CVSS: 10.0)

**Descrizione:**

Il server web Apache in uso espone la versione 2.8.4 del modulo *mod\_ssl*, la quale risulta affetta da una grave vulnerabilità di corruzione della memoria. Questa falla, comunemente nota nel settore come "**OpenSSL-too-open**" (sfruttabile tramite noti exploit pubblici come "**OpenFuck**"), interessa l'implementazione del protocollo crittografico obsoleto **SSLv2**.

**Dettaglio Tecnico e Sfruttamento:**

La vulnerabilità si innesca nello specifico durante il processo di handshake crittografico del protocollo SSLv2 (fase di *client key exchange*). A causa di una scorretta gestione e di una copia erranea della chiave di sessione, l'invio di una chiave di dimensioni volutamente anomale da parte di un client esterno provoca un superamento dei limiti di memoria allocata (**Buffer Overflow**). Durante le fasi di test, l'invio di un payload malevolo appositamente costruito ha permesso di sovrascrivere lo stack di esecuzione, forzando il server a eseguire codice arbitrario. L'azione dell'exploit genera una shell interattiva che viene eseguita come processo figlio del demone web. Di conseguenza, l'accesso remoto ottenuto opera limitatamente ai privilegi dell'utente di sistema standard "**apache**".

**Impatto:**

Sebbene l'esecuzione dell'exploit non avvenga direttamente con i massimi privilegi, la gravità della vulnerabilità rimane estrema. Ottenendo un primo accesso al server, un attaccante remoto può:

- Leggere e alterare i **file di configurazione** del server web e i dati dei siti ospitati.
- Accedere a **database locali** qualora vi siano credenziali salvate in chiaro.
- Sfruttare questo accesso come "testa di ponte" fondamentale per eseguire successivi attacchi di **Privilege Escalation locale** (come la vulnerabilità del Kernel descritta di seguito).

### 3.1.3 Privilege Escalation locale tramite Vulnerabilità del Kernel (ptrace-kmod)

**Livello di Rischio:**

**CRITICO** (CVSS: 10.0)

**Descrizione:**

La macchina target utilizza una versione del kernel Linux (famiglia 2.4) affetta da una nota e grave vulnerabilità che coinvolge il tracciamento dei processi (*ptrace*) e il caricamento dei moduli del kernel (*kmod*).

**Dettaglio Tecnico e Sfruttamento:**

Sebbene l'exploit non sia eseguibile direttamente da remoto senza autenticazione, esso diventa letale se combinato con le vulnerabilità dei servizi esposti. Un attaccante che riesce a ottenere una shell iniziale con privilegi minimi (ad esempio sfruttando la compromissione del servizio Apache) può trasferire, compilare ed eseguire l'exploit **ptrace-kmod** localmente sulla macchina. Questo permette di aggirare le restrizioni del sistema operativo e scalare immediatamente i permessi.

**Impatto:**

La compromissione tramite questa vulnerabilità porta alla perdita totale di riservatezza, integrità e disponibilità del sistema. Ottenendo i permessi di amministratore, l'attaccante ha il controllo incondizionato della macchina: può accedere a qualsiasi file, alterare le configurazioni di sistema e installare **backdoor permanenti** nel core dell'infrastruttura.

## 3.2 Scenari di Compromissione

Sulla base dell'analisi tecnica delle singole vulnerabilità, è possibile delineare due distinti scenari di attacco che conducono all'ottenimento dei permessi di **root**:

- **Percorso Diretto (Single-Step):** Sfruttamento della criticità individuata nel servizio **Samba**. Questo vettore consente a un attaccante esterno di aggirare completamente l'autenticazione e instaurare direttamente una sessione interattiva remota, operando fin da subito con i massimi privilegi di sistema.
- **Percorso a Catena (Exploit Chaining):** Sfruttamento combinato di vulnerabilità multiple. Inizialmente, la compromissione del server web (tramite la falla nel modulo **OpenSSL**) garantisce un primo accesso remoto alla macchina, seppur con privilegi limitati (utente standard). Successivamente, per acquisire il controllo totale dell'infrastruttura, l'attaccante sfrutta la vulnerabilità locale del **Kernel Linux** eseguendo un'escalation dei privilegi (Privilege Escalation), elevando così i propri permessi fino al livello root.

### 3.3 Impatto sulla sicurezza (Effetti e rischi per l'asset)

L'impatto sulla sicurezza per il sistema analizzato (Kioptrix Level 1) è da considerarsi totale. L'ottenimento dei massimi privilegi di amministrazione (**root**), indipendentemente dal vettore di attacco utilizzato, annulla completamente l'efficacia di qualsiasi controllo di sicurezza locale; il sistema risulta pertanto integralmente compromesso nei suoi tre aspetti fondamentali:

- **Riservatezza (Confidentiality):** L'attaccante ha accesso incondizionato a tutto il file system, potendo leggere ed esfiltrare database, file di configurazione, codice sorgente e credenziali crittografate (come gli hash delle password) senza attivare alcun allarme.
- **Integrità (Integrity):** Viene garantita la possibilità di alterare i dati ospitati sul server, modificare i file di log per cancellare le tracce dell'intrusione (tecniche di anti-forensics) e installare impianti malevoli persistenti (come **rootkit** o **backdoor**) per mantenere l'accesso nel tempo.
- **Disponibilità (Availability):** Il controllo totale permette di interrompere arbitrariamente i servizi in esecuzione (quali Samba e Apache), bloccare gli amministratori legittimi o, nello scenario peggiore, distruggere irrimediabilmente i dati rendendo la macchina inutilizzabile per gli scopi aziendali.

### 3.4 Valutazione esposizione (Possibili conseguenze operative e di sicurezza)

I servizi di rete vulnerabili risultano costantemente esposti (**H24**) e accessibili senza alcun requisito di autenticazione preventiva. Questa disponibilità continua, unita alla presenza in rete di exploit di pubblico dominio (es. integrati in framework come **Metasploit**) e facilmente automatizzabili, abbassa drasticamente la barriera d'ingresso per un potenziale attaccante. La probabilità che l'asset venga preso di mira e violato con successo è pertanto da ritenersi **estremamente elevata**.

## 4 REMEDIATION REPORT

### 4.1 Piano di mitigazione

Il piano di mitigazione per la macchina Kioptrix Level 1 si articola sui seguenti punti chiave, derivati dalle evidenze d'analisi:

- **Risoluzione delle falle critiche:** Interventi mirati all'aggiornamento dei servizi software (Samba, OpenSSL) e del Kernel Linux per eliminare i vettori d'attacco a gravità massima.
- **Contenimento ed isolamento perimetrale:** Applicazione immediata di restrizioni di rete (firewalling) per ridurre la superficie di attacco visibile dall'esterno.
- **Aggiornamento infrastrutturale:** Strategia di migrazione del sistema operativo per implementare tecnologie moderne dotate di difese integrate a livello di memoria.

### 4.2 Raccomandazioni di sicurezza

Sulla base delle vulnerabilità emerse, si raccomanda l'applicazione delle seguenti contromisure:

#### Interventi sul servizio OpenSSL / `mod_ssl`

- **Aggiornamento software:** È necessario eseguire l'aggiornamento di OpenSSL almeno alla versione 0.9.6e (o release successive) per sanare il difetto nel protocollo SSLv2.
- **Segmentazione della rete:** Limitare l'accesso alla porta TCP 443 (HTTPS) esclusivamente a specifiche sottoreti autorizzate, riducendo drasticamente l'esposizione al pubblico.
- **Architettura di sicurezza:** Introdurre un sistema di Reverse Proxy opportunamente aggiornato a monte del server web Apache per filtrare e proteggere le connessioni in ingresso.

#### 4.2.1 Interventi sul servizio Samba

- **Aggiornamento software:** Aggiornare l'istanza di Samba alla versione 2.2.8 (o successive) per correggere definitivamente la vulnerabilità associata alla funzione *trans2open*.
- **Gestione del servizio:** Disabilitare temporaneamente il demone Samba nel caso in cui la condivisione di file in rete non risulti strettamente necessaria alle attività operative.
- **Firewalling mirato:** Configurare regole rigide sul firewall perimetrale o locale, consentendo il traffico verso le porte SMB esclusivamente a host o sottoreti esplicitamente fidate.

#### 4.2.2 Interventi sul Kernel Linux

- **Aggiornamento della distribuzione:** Nonostante in passato fosse stata rilasciata una patch specifica (versione kernel 2.7.7) per correggere la falla *ptrace-kmod*, la mitigazione odierna e definitiva richiede un upgrade completo dell'intera distribuzione del sistema operativo.

#### 4.3 Irrobustimento generale del sistema

- **Protezione della memoria:** Aggiornare il sistema operativo a una versione supportata consente di beneficiare, di default, di meccanismi avanzati di protezione della memoria (come ASLR o DEP), progettati appositamente per bloccare e rendere inefficaci i tentativi di sfruttamento tramite Buffer Overflow.

#### 4.4 Obiettivi di Sicurezza

Riduzione del rischio e rafforzamento dell'asset

- **Azzeramento dei vettori RCE e Privilege Escalation:** L'obiettivo fondamentale è l'eliminazione dei difetti strutturali che permettono l'esecuzione di codice da remoto e la scalata automatica ai privilegi di amministratore.
- **Inibizione degli accessi non autorizzati:** Interrompere la possibilità di effettuare l'enumerazione degli utenti e bloccare i tentativi di interazione non autenticata (come le sessioni con password nulle riscontrate in Samba).



## 5 FINDINGS SUMMARY

Di seguito viene presentata la sintesi delle vulnerabilità critiche identificate e sfruttate con successo durante l'attività di Penetration Testing sull'asset Kioptrix Level 1. L'analisi ha rilevato un totale di 130 vulnerabilità, di cui 5 classificate come critiche e 18 di livello alto. La tabella seguente isola i tre vettori di attacco principali, tutti caratterizzati dal massimo punteggio di gravità (CVSS: 10.0) e in grado di garantire all'attaccante il controllo totale dell'infrastruttura (root).

| ID      | Nome Vulnerabilità                 | Target                               | Categoria                  | Rischio |
|---------|------------------------------------|--------------------------------------|----------------------------|---------|
| VULN-01 | RCE su servizio Samba (trans2open) | Porta 139 TCP (Samba 2.2.1a)         | Remote Code Execution      | CRITICO |
| VULN-02 | RCE su Apache (OpenSSL-too-open)   | Porta 443 TCP (mod_ssl 2.8.4)        | Remote Code Execution      | CRITICO |
| VULN-03 | Privilege Escalation (ptrace-kmod) | Sistema Operativo (Kernel Linux 2.4) | Local Privilege Escalation | CRITICO |

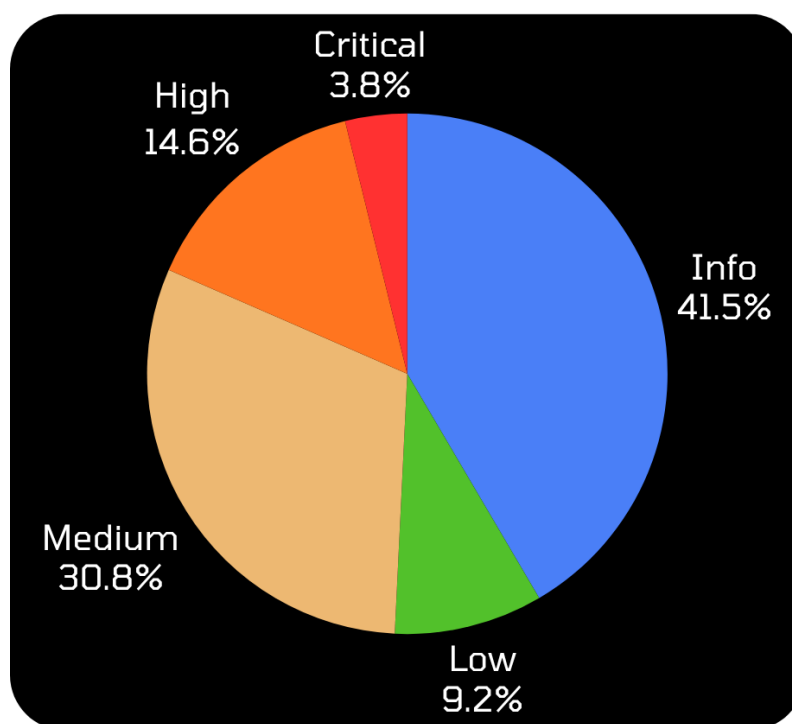
Tabella 1: Riepilogo delle vulnerabilità con CVSS 10.0

## 5.1 Dettaglio delle Scansioni e Superficie di Attacco

A complemento delle criticità di livello massimo evidenziate nella tabella precedente, l'attività di Vulnerability Assessment ha generato una mappatura completa della superficie di attacco. La catalogazione complessiva delle 130 debolezze di sicurezza è derivata dall'utilizzo combinato di diverse metodologie:

- **Scansioni di Rete (Network Scanning):** L'impiego del tool **Nessus** (configurazione: Basic Network Scan) ha rilevato 56 vulnerabilità, mentre lo scanner **OpenVAS** (configurazione: Full and Fast) ne ha isolate 78. È importante sottolineare che, oltre alle criticità CVSS 10.0, sono emerse vulnerabilità di livello medio come l'accesso non autenticato con password nulle su Samba (CVSS 5.3), che ha permesso l'estrazione di informazioni sensibili sul sistema.
- **Verifica Applicativa (Web Application Testing):** I test mirati condotti con strumenti quali **Nikto**, **Nessus Web Scan**, **Dirb** e **Gobuster** hanno appurato che il server web Apache, pur essendo vulnerabile a livello infrastrutturale, non ospita pagine o applicativi web attivi.
- **Esclusione dei Vettori:** Sulla base dei risultati applicativi, è stato possibile escludere con certezza l'eseguitività di vettori d'attacco web standard quali SQL Injection, Cross-Site Scripting (XSS) o File Upload arbitrari.

## 5.2 Grafico delle vulnerabilità rilevate



**Figura 1:** Grafico a torta delle diverse vulnerabilità divise per livello

## 6 DETAILED SUMMARY

Le varie analisi condotte avvalendosi in modo combinato di strumenti quali **Nessus** (per le scansioni infrastrutturali e applicative web) e **OpenVAS**, hanno permesso un'**enumerazione precisa** delle varie vulnerabilità della macchina, identificandone il relativo **livello di pericolosità**.

Il volume complessivo ha prodotto oltre **130 evidenze di sicurezza**. Al fine di restituire un quadro chiaro e privo di ridondanze, i risultati generati dai diversi scanner sono stati incrociati, filtrando i **falsi positivi**, escludendo le pure **note informative** (log/debug) e raggruppando i difetti per **tipologia di servizio esposto**. Di seguito si riporta l'inventario completo delle **criticità tecniche**, ordinate per **comparto logico**.

### 6.1 Catalogo Dettagliato delle Vulnerabilità

#### Classificazione del rischio

Le analisi condotte avvalendosi in modo combinato di strumenti quali Nessus e OpenVAS hanno permesso un'enumerazione precisa delle varie vulnerabilità della macchina, identificandone il relativo livello di pericolosità. Il volume complessivo ha prodotto oltre 130 evidenze di sicurezza. Di seguito si riporta il dettaglio suddiviso per livello di criticità.

### 6.2 Vulnerabilità Critiche

#### 6.2.1 • RCE su servizio Samba trans2open – CVE-2003-0201 (Analisi Manuale, OpenVAS, Nessus)

##### Descrizione:

Il sistema esegue Samba 2.2.1a, un servizio obsoleto esposto ad accessi non autenticati tramite Null Session. La vulnerabilità è causata da un Buffer Overflow nel demone `smbd` innescato durante l'elaborazione di messaggi SMB malformati di tipo *Transaction2 Open*.

##### Rischi:

L'attaccante può sfruttare il difetto di memoria per eseguire codice remoto arbitrario, ottenendo istantaneamente una shell con privilegi di root e il pieno controllo dell'asset.

##### Contromisure:

Aggiornare il servizio Samba alla versione 2.2.8 o successiva, disabilitarlo se non strettamente necessario, oppure limitarne rigorosamente l'esposizione tramite firewall.

### 6.2.2 • RCE su Apache mod\_ssl (OpenSSL-too-open) – CVE-2002-0082 (Nessus, OpenVAS)

**Descrizione:**

Il server Apache utilizza il modulo `mod_ssl` 2.8.4 vulnerabile. La debolezza, identificata tramite Nessus e OpenVAS, risiede in un Buffer Overflow che si manifesta durante la fase di handshake del protocollo SSLv2.

**Rischi:**

Un attacco mirato consente la possibile esecuzione di codice arbitrario da remoto, permettendo all'attaccante di ottenere un primo accesso al server con i privilegi dell'utente `apache`.

**Contromisure:**

Aggiornare la libreria OpenSSL a una release sicura e disabilitare completamente il supporto al protocollo crittografico obsoleto SSLv2.

### 6.2.3 • Privilege Escalation tramite Kernel Linux (ptrace-kmod) – CVE-2003-0127 (Analisi Manuale)

**Descrizione:**

Il sistema operativo si basa sul Kernel Linux 2.4, vulnerabile a causa di un grave difetto logico nella gestione combinata dei componenti `ptrace` e `kmod`. La falla è stata sfruttata localmente durante le attività di post-exploitation.

**Rischi:**

Un attaccante che ha già ottenuto un accesso base al sistema può eseguire un'escalation immediata ai privilegi di root, aggirando le protezioni e compromettendo l'intera macchina.

**Contromisure:**

Aggiornare radicalmente il sistema operativo e il kernel a distribuzioni e versioni moderne attivamente supportate.

## 6.3 Vulnerabilità Alte

### 6.3.1 • Deprecated SSH-1 Protocol Detection – CVE-2001-0361, CVE-2001-0572 (Nessus, OpenVAS)

**Descrizione:**

L'analisi del servizio esposto sulla porta 22/TCP ha rilevato il supporto attivo ai protocolli SSH-1, mantenuto a causa di una configurazione legacy non sicura.

**Rischi:**

L'utilizzo di un protocollo storicamente compromesso espone le sessioni di amministrazione remota a possibili intercettazioni e attacchi di tipo Man-in-the-Middle.

**Contromisure:**

Intervenire sul file di configurazione del demone SSH per forzare e consentire esclusivamente le connessioni tramite il protocollo moderno SSH-2.

### 6.3.2 • Apache Chunked Encoding Remote Overflow – CVE-2002-0392 (Nessus)

**Descrizione:**

Vulnerabilità individuata tramite Nessus e localizzata nel parsing degli header HTTP da parte del server web Apache. Il difetto è generato da un Integer Overflow nella gestione dei trasferimenti con codifica chunked.

**Rischi:**

Lo sfruttamento intenzionale di questa debolezza può portare all'interruzione del servizio (DoS) o favorire l'esecuzione non autorizzata di codice remoto.

**Contromisure:**

Applicare tempestivamente le patch di sicurezza rilasciate per Apache o procedere all'aggiornamento dell'intero applicativo server.

## 6.4 Vulnerabilità Medie

### 6.4.1 • Enumerazione Utenti tramite servizio Samba (Analisi Manuale)

**Descrizione:**

Durante le fasi di verifica manuale, è emerso che il servizio di condivisione Samba consente interrogazioni e accessi non autenticati utilizzando password nulle.

**Rischi:**

Un utente esterno malintenzionato può sfruttare questa apertura per estrarre informazioni sensibili, facilitando una rapida enumerazione degli utenti di sistema.

**Contromisure:**

Riconfigurare i permessi del servizio Samba, bloccando in modo categorico la possibilità di stabilire Null Session anonime.

#### 6.4.2 ● HTTP TRACE / TRACK Methods Allowed – CVE-2003-1567 (Nessus)

**Descrizione:**

La verifica dei metodi HTTP supportati ha evidenziato che i comandi di debugging TRACE e TRACK sono attivi, indicando un mancato hardening del server web.

**Rischi:**

L'attivazione di questi metodi diagnostici facilita la conduzione di possibili attacchi Cross-Site Tracing (XST) contro gli utenti che navigano l'applicativo.

**Contromisure:**

Disabilitare esplicitamente il metodo configurando la direttiva `TraceEnable Off` all'interno del file di configurazione di Apache.

#### 6.4.3 ● Webalizer Cross Site Scripting – CVE-2001-0835 (Nessus, OpenVAS)

**Descrizione:**

L'analisi delle directory web esposte ha portato alla luce una vulnerabilità XSS presente nell'applicativo Webalizer. Il problema deriva da una sanitizzazione insufficiente degli input processati.

**Rischi:**

Un attaccante potrebbe indurre il browser di una vittima a eseguire script malevoli, causando il furto di sessione o l'esecuzione di azioni arbitrarie non autorizzate.

**Contromisure:**

Aggiornare il software Webalizer a una versione sicura o, qualora non strettamente necessario, rimuoverne l'installazione dal server web.

### 6.5 Vulnerabilità Basse

#### 6.5.1 ● ICMP Timestamp Reply Information Disclosure – CVE-1999-0524 (Nessus, OpenVAS)

**Descrizione:**

Inviando specifiche richieste ICMP di Type 13, è stato confermato che il sistema target restituisce risposte ai pacchetti ICMP Timestamp.

**Rischi:**

Questo comportamento agevola la raccolta di informazioni temporali e operative sul sistema, facilitando la fase di ricognizione.

## 7 Considerazioni finali

L'attività di **Penetration Testing** condotta sull'infrastruttura **Kioptrix Level 1** ha fatto emergere un quadro di sicurezza estremamente critico. La presenza di vulnerabilità storiche, ampiamente documentate e di pubblico dominio, combinata con l'assenza di una politica di aggiornamento strutturale, espone l'asset a compromissioni totali e immediate da parte di attaccanti esterni, operanti anche in totale assenza di credenziali valide.

Il conseguimento dei massimi privilegi di sistema (**root**) attraverso molteplici e distinti vettori di attacco (servizio Samba, modulo OpenSSL e Kernel Linux) dimostra in modo inequivocabile che l'attuale configurazione non è in grado di garantire i requisiti minimi di **Riservatezza, Integrità e Disponibilità** dei dati aziendali.

Si raccomanda ai referenti dell'infrastruttura di procedere con **estrema urgenza** all'applicazione del piano di mitigazione illustrato nel presente report. Nello specifico, data l'obsolescenza profonda delle componenti (come il Kernel obsoleto), si sconsiglia il semplice "patching" dei singoli servizi in favore di una **migrazione completa del sistema operativo** verso distribuzioni moderne, attivamente supportate e dotate di difese in memoria native.

Fino al completamento e alla validazione di tali interventi di sicurezza, l'asset deve essere considerato **altamente vulnerabile** e deve essere, se possibile, **isolato a livello perimetrale** come un utilizzo di Firewall per prevenire incidenti di sicurezza che potrebbero potenzialmente estendersi in un'ipotetica rete esterna.

## 8 Riferimenti bibliografici

### Riferimenti bibliografici

- [1] National Vulnerability Database (NVD) – NIST.  
**CVE-2003-0201** – Samba *call\_trans2open* Remote Buffer Overflow.  
Buffer overflow nella funzione `call_trans2open` di `trans2.c` in Samba 2.2.x (prima della 2.2.8a), che consente a un attaccante remoto di eseguire codice arbitrario.  
<https://nvd.nist.gov/vuln/detail/CVE-2003-0201>
- [2] National Vulnerability Database (NVD) – NIST.  
**CVE-2002-0082** – Apache `mod_ssl` < 2.8.7 (*OpenSSL-too-open*) Remote Buffer Overflow.  
Il codice di gestione delle sessioni (dbm e shm) in `mod_ssl` prima della versione 2.8.7-1.3.23 non inizializza correttamente la memoria tramite la funzione `i2d_SSL_SESSION`, permettendo a un attaccante remoto di eseguire codice arbitrario tramite un Buffer Overflow.  
<https://nvd.nist.gov/vuln/detail/CVE-2002-0082>
- [3] National Vulnerability Database (NVD) – NIST.  
**CVE-2003-0127** – Linux Kernel *ptrace/kmod* Local Privilege Escalation.  
Il loader dei moduli del kernel Linux 2.2.x (prima della 2.2.25) e 2.4.x (prima della 2.4.21) consente agli utenti locali di ottenere privilegi di root sfruttando `ptrace` per agganciarsi a un processo figlio avviato dal kernel.  
<https://nvd.nist.gov/vuln/detail/CVE-2003-0127>
- [4] National Vulnerability Database (NVD) – NIST.  
**CVE-2014-3566** – POODLE: Padding Oracle On Downgraded Legacy Encryption (SSLv3).  
<https://nvd.nist.gov/vuln/detail/CVE-2014-3566>
- [5] National Vulnerability Database (NVD) – NIST.  
**CVE-2016-2183** – SWEET32: Birthday Attack su cifrari a blocchi a 64-bit (3DES, Blowfish).  
<https://nvd.nist.gov/vuln/detail/CVE-2016-2183>
- [6] National Vulnerability Database (NVD) – NIST.  
**CVE-2015-0204** – FREAK: RSA Export Keys Downgrade Attack.  
<https://nvd.nist.gov/vuln/detail/CVE-2015-0204>
- [7] National Vulnerability Database (NVD) – NIST.  
**CVE-2015-4000** – Logjam: Attacco di downgrade su DHE\_EXPORT (Diffie-Hellman a 512-bit).  
<https://nvd.nist.gov/vuln/detail/CVE-2015-4000>
- [8] National Vulnerability Database (NVD) – NIST.  
**CVE-2016-0800** – DROWN: Decrypting RSA with Obsolete and Weakened eNcryption (SSLv2 cross-protocol attack).  
<https://nvd.nist.gov/vuln/detail/CVE-2016-0800>



- [9] Rapid7.  
**Metasploit Framework** – Framework open-source per lo sviluppo e l'esecuzione di exploit.  
Utilizzato nel test per sfruttare le vulnerabilità *trans2open* (CVE-2003-0201).  
<https://www.metasploit.com>
- [10] Tenable, Inc.  
**Nessus** – Scanner di vulnerabilità di rete. Versione utilizzata: Basic Network Scan & Web Application Tests.  
<https://www.tenable.com/products/nessus>
- [11] Greenbone Networks.  
**OpenVAS (Open Vulnerability Assessment System)** – Scanner di vulnerabilità open-source. Versione utilizzata: configurazione *Full and Fast*.  
<https://www.greenbone.net/en/vulnerability-management/>
- [12] CIRT.net.  
**Nikto** – Web server scanner open-source per l'identificazione di vulnerabilità nei server HTTP/HTTPS.  
<https://cirt.net/Nikto2>
- [13] The Security Factory.  
**DIRB** – Web content scanner per l'enumerazione di directory e file nascosti su server web.  
<https://dirb.sourceforge.net>
- [14] OJ Reeves.  
**Gobuster** – Tool di directory/file brute-forcing scritto in Go, utilizzato per il crawling del server Apache.  
<https://github.com/OJ/gobuster>
- [15] Samba Team.  
**rpcclient** – Utility del pacchetto Samba per l'interrogazione di servizi RPC/SMB remoti. Utilizzata per verificare l'accesso non autenticato (Null Session) al servizio Samba.  
<https://www.samba.org/samba/docs/current/man-html/rpcclient.1.html>
- [16] FIRST (Forum of Incident Response and Security Teams).  
**Common Vulnerability Scoring System (CVSS) v3.1** – Standard per la valutazione della severità delle vulnerabilità.  
<https://www.first.org/cvss/specification-document>
- [17] National Institute of Standards and Technology (NIST).  
**National Vulnerability Database (NVD)** – Database ufficiale delle vulnerabilità note.  
<https://nvd.nist.gov>